

■■ Security Assessment Report

VulnAssess Pro — Automated Vulnerability Analysis

Target: <https://www.dbu.edu.et/>

Scan Type: WEB Security Assessment

Date: May 29, 2026 at 12:40

Classification: CONFIDENTIAL

This document contains confidential security assessment findings. Distribution should be limited to authorized personnel only.

1. Executive Summary

A comprehensive security assessment was performed on <https://www.dbu.edu.et/>. The assessment identified **10 vulnerabilities** with an overall security score of **44.0/100**. The overall risk level is classified as **High**.

2. Risk Score Overview

Overall Security Score: 44.0/100

Severity	Count	Weight
Critical	0	25 pts each
High	2	15 pts each
Medium	2	8 pts each
Low	6	3 pts each
Total	10	

3. Vulnerability Summary

#	Vulnerability	Severity	Category
1	Missing Strict-Transport-Security Header	HIGH	Security Headers
2	Missing Content-Security-Policy Header	HIGH	Security Headers
3	Missing X-Content-Type-Options Header	MEDIUM	Security Headers
4	Missing X-Frame-Options Header	MEDIUM	Security Headers
5	Missing X-XSS-Protection Header	LOW	Security Headers
6	Missing Referrer-Policy Header	LOW	Security Headers
7	Missing Permissions-Policy Header	LOW	Security Headers
8	Technology Stack Disclosed	LOW	Information Disclosu
9	Email Address Exposed	LOW	Information Disclosu
10	Internal IP Address Exposed	LOW	Information Disclosu

4. Detailed Findings

4.1 Missing Strict-Transport-Security Header

[HIGH] — Category: Security Headers

Description: HTTP Strict Transport Security (HSTS) header is missing

Impact: Users may be vulnerable to man-in-the-middle attacks via protocol downgrade

Remediation: Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Sec

4.2 Missing Content-Security-Policy Header

[HIGH] — Category: Security Headers

Description: Content Security Policy (CSP) header is missing

Impact: The application may be vulnerable to Cross-Site Scripting (XSS) and data injection attacks

Remediation: Implement a Content-Security-Policy header with appropriate directives Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security

4.3 Missing X-Content-Type-Options Header

[MEDIUM] — Category: Security Headers

Description: X-Content-Type-Options header is missing

Impact: Browser may perform MIME-type sniffing leading to security vulnerabilities

Remediation: Add 'X-Content-Type-Options: nosniff' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security for HTTPS enforcement 5.

4.4 Missing X-Frame-Options Header

[MEDIUM] — Category: Security Headers

Description: X-Frame-Options header is missing

Impact: The application may be vulnerable to clickjacking attacks

Remediation: Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security fo

4.5 Missing X-XSS-Protection Header

[LOW] — Category: Security Headers

Description: X-XSS-Protection header is missing

Impact: Browser XSS filter may not be enabled

Remediation: Add 'X-XSS-Protection: 1; mode=block' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security for HTTPS enforcement 5.

4.6 Missing Referrer-Policy Header

[LOW] — Category: Security Headers

Description: Referrer-Policy header is missing

Impact: Sensitive information may be leaked through the Referer header

Remediation: Add 'Referrer-Policy: strict-origin-when-cross-origin' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security for HTTP

4.7 Missing Permissions-Policy Header

[LOW] — Category: Security Headers

Description: Permissions-Policy header is missing

Impact: Browser features may be used without restriction by third-party content

Remediation: Add a Permissions-Policy header to control browser feature access Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY to prevent clickjacking 3. Set X-Content-Type-Options: nosniff to prevent MIME sniffing 4. Enable Strict-Transport-Security for

4.8 Technology Stack Disclosed

[LOW] — Category: Information Disclosure

Description: X-Powered-By header reveals: PHP/8.2.31, PleskLin

Impact: Technology stack information helps attackers target specific vulnerabilities

Evidence: X-Powered-By: PHP/8.2.31, PleskLin

Remediation: Remove the X-Powered-By header from server responses Detailed Steps: 1. Remove or obscure Server header version information 2. Remove X-Powered-By and other technology-revealing headers 3. Sanitize error messages to prevent stack trace exposure 4. Remove HTML comments containing sensitive informati

4.9 Email Address Exposed

[LOW] — Category: Information Disclosure

Description: Potentially sensitive information found in page content

Impact: Exposed information can be used for social engineering or targeted attacks

Evidence: Found: FPR@dbu.edu.et, dbu@dbu.edu.et, registrar@dbu.edu.et

Remediation: Review and remove sensitive information from public-facing pages Detailed Steps: 1. Remove or obscure Server header version information 2. Remove X-Powered-By and other technology-revealing headers 3. Sanitize error messages to prevent stack trace exposure 4. Remove HTML comments containing sensi

4.10 Internal IP Address Exposed

[LOW] — Category: Information Disclosure

Description: Potentially sensitive information found in page content

Impact: Exposed information can be used for social engineering or targeted attacks

Evidence: Found: 10.18.3

Remediation: Review and remove sensitive information from public-facing pages Detailed Steps: 1. Remove or obscure Server header version information 2. Remove X-Powered-By and other technology-revealing headers 3. Sanitize error messages to prevent stack trace exposure 4. Remove HTML comments containing sensitive information

5. Recommendations

■ High Priority:

- Fix: Missing Strict-Transport-Security Header — Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks
- Fix: Missing Content-Security-Policy Header — Implement a Content-Security-Policy header with appropriate directives Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2.

■ Medium Priority:

- Fix: Missing X-Content-Type-Options Header — Add 'X-Content-Type-Options: nosniff' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add X-Frame-Options: DENY
- Fix: Missing X-Frame-Options Header — Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' header Detailed Steps: 1. Implement Content-Security-Policy to prevent XSS attacks 2. Add

6. Conclusion

The security assessment of <https://www.dbu.edu.et/> revealed **10 vulnerability/vulnerabilities** with an overall security score of **44.0/100**. It is recommended to prioritize remediation of critical and high-severity findings first, followed by medium and low-severity issues. A follow-up assessment should be conducted after remediation to verify the effectiveness of the applied fixes.

Report generated by VulnAssess Pro on May 29, 2026 at 12:40:13